Secure Skies, Inc. – FAIR Risk Analysis

Monte Carlo Simulation with BetaPERT Distributions

Group 1 – Secure Skies Investigation Team

March 31, 2026

Contents

1 Executive Summary **2**

2 FAIR Methodology **3**

2.1 Core Model . . . 3

2.2 How BetaPERT Distributions Model Uncertainty . . . 3

2.3 Simulation Algorithm . . . 4

2.4 Vulnerability vs. Probability of Loss: Key Distinction . . . 4

2.5 Calibration Scale and Evidence Basis . . . 4

2.5.1 Threat Event Frequency (TEF) . . . 4

2.5.2 Threat Capability (TC) and Control Difficulty (DIFF) — The 0–100 Scale . 5

2.5.3 Loss Magnitude (LM) . . . 6

3 Scenario Inventory **6**

4 Monte Carlo Simulation **10**

4.1 BetaPERT Distribution Shapes . . . 10

4.2 Illustrative Raw Iterations for WEB-01 . . . 11

4.3 Full Simulation . . . 11

5 Results **12**

5.1 Per-Scenario Summary Statistics . . . 12

5.2 Domain Aggregated ALE . . . 15

6 Visualisations **15**
6.1 ALE Ranked Bar Chart (Top 15 Scenarios) 15
6.2 Domain Risk Heatmap 15
6.3 Loss Distribution Ridgeline 15
6.4 Loss Exceedance Curve 18
6.5 Vulnerability vs. ALE Scatter 18
6.6 Top-10 Scenario Loss Histograms 18

7 Priority Rankings and Key Findings **18**

8 Appendix A: All Scenario BetaPERT Parameters **23**

9 Appendix B: Evidence Sources **25**

10 Appendix C: Key References **28**

11 Appendix D: Session Info **28**

---

1 Executive Summary

This report fulfils all four objectives specified in the CEO's memorandum and the FAIR Analysis Assignment Description:

1. **Quantify the Bleeding** (§2–§5): FAIR Monte Carlo simulation translates each confirmed vulnerability into probabilistic annual loss figures with full uncertainty ranges.
2. **Scenario Mapping** (§3): All ten incident reports SS1–SS10 are individually mapped to dedicated FAIR scenarios, with additional scenarios derived from live recon and organisational data.
3. **Predictive Modelling** (§4–§5): 100,000 Monte Carlo iterations per scenario produce worst-case (p95), median, and mean ALE estimates.
4. **Prioritise Risks** (§7): All scenarios are ranked by ALE p95 with full justification.

All loss estimates use **BetaPERT** distributions calibrated to: incident reports SS1–SS10 (confirmed losses, dwell times, scope); live reconnaissance (evidence cut-off 2026-03-14) including confirmed active exfiltration `send_db.py`, 22-day undetected web shell, Samba 4.6.2 CVEs, anonymous LDAP, and OpenSSH 8.7 on Security Onion; 2026 Salary Mapping (CEO $1 salary, terminated R&D employee, commission structure); and a dedicated **Legal, Regulatory & Contractual Liability** domain modelling downstream civil and regulatory consequences of the confirmed breaches.

34 scenarios across **7 domains** are evaluated. The primary metric is the **95th-percentile ALE (ALE p95)**.

---

2 FAIR Methodology

2.1 Core Model

FAIR (Factor Analysis of Information Risk) is a quantitative framework that decomposes risk into two dimensions:

$$\text{Annual Loss} = \text{Loss Event Frequency (LEF)} \times \text{Loss Magnitude (LM)}$$

where Loss Event Frequency combines threat frequency with attacker success probability:

$$\text{LEF} = \text{TEF} \times \text{Vulnerability}, \qquad \text{Vulnerability} = \Pr(\text{TC} > \text{DIFF})$$

Each input factor is modelled as a **BetaPERT distribution** parameterised by three expert-elicited points (minimum, most-likely, maximum), capturing both the best estimate and the uncertainty around it. The BetaPERT is preferred over a triangular distribution because it places relatively less probability mass at the extremes, producing smoother, more realistic tails.

2.2 How BetaPERT Distributions Model Uncertainty

A BetaPERT distribution with parameters (L, ML, H) has:

$$\text{Mean} = \frac{L + 4 \cdot ML + H}{6}, \qquad \text{Variance} = \frac{(\text{Mean} - L)(H - \text{Mean})}{7}$$

The width of the distribution — and therefore the uncertainty it encodes — is determined by the gap between L and H:

- **Narrow gap** (e.g. TEF Continuous: 15–260 events/yr on a log scale): Relatively concentrated distribution; expert is more confident.
- **Wide gap** (e.g. LM Very High: \$1.5M–\$15M): Fat-tailed distribution; expert has high uncertainty about the exact loss, but is confident it falls within this order of magnitude.

This three-point parameterisation allows analysts to express *what they know* (the most-likely value) and *what they don't know* (the plausible range) in a single tractable distribution. Because TC, DIFF, TEF, and LM are each drawn independently in each Monte Carlo iteration, their uncertainties propagate multiplicatively through the annual loss calculation, producing output uncertainty that is wider than any single input — correctly reflecting real-world risk estimation under compound uncertainty.

2.3 Simulation Algorithm

For each of the 100,000 iterations per scenario:

1. Draw $\text{TEF}_i \sim \text{BetaPERT}(L_{\text{tef}}, ML_{\text{tef}}, H_{\text{tef}})$ — how often does the threat act this year?
2. Draw $\text{TC}_i \sim \text{BetaPERT}(L_{\text{tc}}, ML_{\text{tc}}, H_{\text{tc}})$ — how capable is the attacker?
3. Draw $\text{DIFF}_i \sim \text{BetaPERT}(L_{\text{diff}}, ML_{\text{diff}}, H_{\text{diff}})$ — how strong are the controls?
4. $\text{Vuln}_i = \mathbf{1}[\text{TC}_i > \text{DIFF}_i]$ — did the attacker overcome controls?
5. $\text{LEF}_i \sim \text{Poisson}(\text{TEF}_i \times \text{Vuln}_i)$ — how many loss events occurred?
6. Draw $\text{LM}_i \sim \text{BetaPERT}(L_{\text{lm}}, ML_{\text{lm}}, H_{\text{lm}})$ — how much did each event cost?
7. Annual $\text{Loss}_i = \text{LEF}_i \times \text{LM}_i$

Why Poisson in step 5? TEF is a continuous annual rate. For TEF = 0.1 events/yr (once per 10 years), a simple floor would yield zero every iteration, incorrectly assigning 0% P(Loss). The Poisson model gives $P(\text{LEF} \geq 1) = 1 - e^{-0.1} \approx 9.5\%$ — correctly reflecting that a threat expected once per decade has roughly a 1-in-10 chance of occurring in any given year.

2.4 Vulnerability vs. Probability of Loss: Key Distinction

These two statistics are frequently confused but answer fundamentally different questions:

Vulnerability % = Pr(TC > DIFF): *"Given a single threat attempt, how likely is the attacker to succeed?"* This is a competency ratio. It says nothing about how often an attempt occurs. A scenario with 100% vulnerability but TEF = 0.1 means the attacker always wins when they try — but they only try about once per decade.

P(Loss) % $= 1 - e^{-\overline{\text{TEF}} \times \overline{\text{Vuln}}}$: *"What is the probability at least one loss event occurs this year?"* This combines both how often the threat acts and whether it succeeds.

A scenario with 0.00% P(Loss) despite non-zero Vulnerability has TEF so low that the Poisson draw produces zero events in virtually all simulated years. This is mathematically correct, not a modelling error. Scenarios SC-01, SC-03, SC-04 have TEF ML = 0.1 events/yr, giving $P(\text{Loss}) = 1 - e^{-0.1 \times \text{Vuln}} \approx 9.5\%$ at most — any value below that rounds to a small percentage in the table.

Uncertainty on Vulnerability and P(Loss): Because both statistics are sample proportions from \$N = \$ 100,000 Bernoulli trials, we report 95% Wilson confidence intervals alongside each point estimate. The Wilson interval is preferred over the Wald interval because it has correct coverage near 0% and 100% (Agresti & Coull, 1998; Brown, Cai & DasGupta, 2001).

2.5 Calibration Scale and Evidence Basis

2.5.1 Threat Event Frequency (TEF)

TEF calibration uses three primary sources:

Verizon DBIR 2024 (verizon.com/dbir): $n \approx 30{,}000$ incidents. Web Application Attack pattern \$ \$26% of confirmed breaches; System Intrusion \$ 23%; $Social Engineering$ \$17%. For a mid-market payment-processing company:

- **Rare (∼0.1/yr)**: DBIR Physical/Lost-Device pattern; median 1 per 10 yrs for SMBs. Applied to SS4, SS8, SS9.
- **Occasional (∼1/yr)**: DBIR BEC/Social Engineering + Supply Chain; 0.5–2/yr for this sector. Applied to SS1, SS3, SS7, SS2, SS10, and related legal consequences.
- **Frequent (∼6/yr)**: CISA KEV catalogue active exploitation; CrowdStrike GTR 2024 reports 6–15 web app attacks/yr against payment targets.
- **Continuous (∼52/yr)**: Confirmed persistent processes (`send\_db.py` PID 3390, anonymous LDAP enumeration accessible from any internal host).

2.5.2 Threat Capability (TC) and Control Difficulty (DIFF) — The 0–100 Scale

The 0–100 scale is a normalised representation of adversary capability calibrated to **CVSS v3.1 Base Scores** (FIRST CVSS v3.1 Specification). CVSS Exploitability sub-scores assess Attack Vector, Attack Complexity, Privileges Required, and User Interaction — directly mapping to attacker capability relative to the defender:

- **Low (15–42)**: CVSS Attack Complexity High or Privileges Required High. Script-kiddie, opportunistic. No custom tooling.
- **Medium (38–68)**: CVSS 7–8 class exploits. Skilled e-crime actor (FIN7, Scattered Spider profile). Standard toolkits (Metasploit, Cobalt Strike).
- **High (60–88)**: CVSS 9–10 class exploits or APT-grade. SambaCry (10.0), Apache mod_rewrite (9.8), regreSSHion (8.1). Nation-state interest in drone technology (cf. MITRE ATT&CK G0019).

Control Difficulty uses the same 0–100 scale: a Very Low DIFF (3–18) means controls are confirmed absent or failing per reconnaissance evidence; a High DIFF (60–88) means robust, tested controls are in place. For Secure Skies, almost all DIFF values are Very Low (3–18) because recon confirms controls to be absent or bypassed.

Table 1: CVE and Technique to TC Calibration Mapping (CVSS v3.1)

CVE / Technique	CVSS	Mapped TC Range	Applied To
CVE-2017-7494 SambaCry	10.0	High (60-88)	ID-01: public Metasploit module; no auth; 9-yr-old exploit in CISA KEV
CVE-2024-6387 regreSSHion	8.1	Med-High (38-68)	ID-06: signal handler race; unauthenticated; Security Onion unpatched
CVE-2024-38476 Apache RCE	9.8	High (60-88)	WEB-02: unauthenticated mod_rewrite RCE; confirmed unpatched on web server
CVE-2024-27316 Apache DoS	7.5	Medium (38-68)	WEB-02 (secondary): DoS only; lower impact than RCE
LDAP anonymous bind	N/A	Low (15-28)	ID-02: no exploit needed; enumeration only; confirmed on all 4 LDAP ports
BEC / MFA fatigue (SS1)	N/A	Medium (38-52)	ID-05: social engineering; requires victim error; confirmed successful
Password spray (SS7)	N/A	Low (15-28)	ID-04: low-and-slow; Patricia Long weak password cracked
USB autorun malware (SS8)	N/A	Medium (38-52)	SC-03: contractor physical access; known malware family

2.5.3 Loss Magnitude (LM)

LM ranges are anchored to six published sources plus confirmed Secure Skies data:

Table 2: Loss Magnitude Calibration with Evidence Basis

LM Label	Range	Evidence Basis	Reference / URL
Very Low	\$500-\$6K	Internal IT remediation only (<1 day). Confirmed no external exposure. IC3 2023 micro-firm tail-low.	ic3.gov/AnnualReport/2023_IC3Report.pdf
Low	\$3K-\$30K	SS1 confirmed \$27,450 BEC loss anchors ML. FBI IC3 2023: BEC median \$8K for firms <50 employees. NetDiligence 2023 micro-firm median claim \$17K.	ic3.gov/AnnualReport/2023_IC3Report.pdf
Medium	\$10K-\$120K	Moderate breach: PCI notification (~1K records), legal retainer, basic forensics. NetDiligence 2023 micro-firm mean claim \$50K.	netdiligence.com/cyber-claims-study
High	\$30K-\$300K	Serious breach: PCI fines (2 brands), QIRA forensics (\$30-\$80K), 36K-record notification. NetDiligence small-firm mean claim \$182K.	netdiligence.com/cyber-claims-study
Very High	\$50K-\$800K	Existential-scale event: DTSA judgment (\$200K-\$500K per Littler 2024 small-firm), full card breach + PCI decertification, M\&A deal collapse. \$800K ceiling = ~16\% of estimated annual revenue.	littler.com/publication-press/publication/2024-report

Table 3: BetaPERT Cali

Factor	Label	Low	ML	High	Unit
TEF: Threat Event Frequency (DBIR 2024 / CISA KEV)					
TEF	Rare	5.0e-02	1.0e-01	5.0e-01	evt/yr
TEF	Occasional	3.3e-01	1.0e+00	3.0e+00	evt/yr
TEF	Frequent	3.0e+00	6.0e+00	1.5e+01	evt/yr
TEF	Continuous	1.5e+01	5.2e+01	2.6e+02	evt/yr
TC / DIFF – CVSS v3.1 Exploitability anchors					
TC/DIFF	Low	1.5e+01	2.8e+01	4.2e+01	0-100
TC/DIFF	Medium	3.8e+01	5.2e+01	6.8e+01	0-100
TC/DIFF	High	6.0e+01	7.4e+01	8.8e+01	0-100
Loss Magnitude – IBM 2024 / DBIR / IC3 / NetDiligence / Littler					
LM	Very Low	5.0e+02	2.0e+03	6.0e+03	USD
LM	Low	3.0e+03	1.5e+04	3.0e+04	USD
LM	Medium	1.0e+04	5.0e+04	1.2e+05	USD
LM	High	3.0e+04	1.0e+05	3.0e+05	USD
LM	Very High	5.0e+04	2.0e+05	8.0e+05	USD

NOTE: Continuous TEF (52/yr) is reserved for ongoing automated processes. Confirmed one-time breach events (WEB-01, WEB-03, DS-04) us

---

3 Scenario Inventory

Coverage of all ten incident reports: SS1 → ID-05; SS2 → DS-01, LEG-03; SS3 → SC-01, LEG-04; SS4 → ID-07; SS5 → SC-02; SS6 → DS-02; SS7 → ID-04, LEG-02; SS8 → SC-03; SS9 →

SC-04; SS10 → DS-03, IR-03. Additional scenarios derive from live recon (WEB-01/02/03/04, ID-01/02/03/06), org data (OPS-01 through OPS-06), and confirmed active attack chain (IR-01/02). Legal consequences of the breaches are captured in LEG-01 through LEG-05.

Table 4: FAIR Scenario Inventory (all 34 scenarios; SS1-SS10 all mapped)

ID	Domain	Scenario	Threat Actor	MITRE ATT\&CK
WEB-01	WEB	Active payment data exfiltration via send_db.py	External Adversary	T1505,T1567.004,T1213
WEB-02	WEB	SQL injection on payment portal leading to RCE	External Adversary	T1190,T1203,T1059.005
WEB-03	WEB	Web shell persistence via uploaded PHP reverse shell (reverse6.php)	External Adversary	T1505,T1036
WEB-04	WEB	Credential pivot from web server to R&D via jruecker account	External Adversary	T1552.001,T1078
ID-01	ID	Samba 4.6.2 unauthenticated RCE via CVE-2017-7494 (SambaCry, CVSS 10.0)	External Adversary	T1210,T1068
ID-02	ID	Anonymous LDAP enumeration enabling targeted credential attacks	External Adversary / Insider	T1087.002,T1018
ID-03	ID	LDAPS certificate expiry (2026-07-15) causing org-wide auth failure	Internal / Operational Failure	NA
ID-04	ID	Password spray against O365 leading to account compromise (SS7)	External Adversary	T1110.003,T1114.002,T1078
ID-05	ID	MFA fatigue attack on finance account leading to BEC and payroll redirect (SS1)	External Adversary	T1621,T1078,T1114.003,T1020
ID-06	ID	Security Onion CVE-2024-6387 regreSSHion unauthenticated RCE (CVSS 8.1)	External Adversary	T1210
ID-07	ID	Stolen contractor laptop enabling VPN session and internal document access (SS4)	External Adversary	T1078,T1133
DS-01	DS	Malicious insider source code exfiltration — drone flight-control IP (SS2)	Malicious Insider	T1537,T1052
DS-02	DS	Cloud storage IAM misconfiguration exposing drone design artifacts (SS6)	External Adversary	T1530
DS-03	DS	CI/CD token exposure enabling container image backdoor (SS10)	External Adversary	T1528,T1525
DS-04	DS	db.json payment database exposed in web root — direct bulk exfiltration	External Adversary	T1005,T1213
SC-01	SC	SaaS supply chain JavaScript injection harvesting 86 employee SSO credentials (SS3)	External Adversary via Third Party	T1195.002,T1078,T1110
SC-02	SC	IoT camera compromise — default credentials, internal network pivot (SS5)	External Adversary	T1078,T1046,T1059
SC-03	SC	USB malware on CNC workstation with lateral SMB scanning (SS8)	External Adversary via Contractor	T1091,T1053.005,T1046
SC-04	SC	Evil-twin Wi-Fi AP intercepting VPN credentials near HQ (SS9)	External Adversary	T1557,T1669
SC-05	SC	Rogue unregistered host 192.168.40.40 in sales subnet	External Adversary / Insider	T1200,T1016
IR-01	IR	22-day undetected web server compromise — catastrophic detection failure	External Adversary	T1505,T1070.002

Table 4: FAIR Scenario Inventory (all 34 scenarios; SS1-SS10 all mapped) *(continued)*

ID	Domain	Scenario	Threat Actor	MITRE ATT\&CK
IR-02	IR	Ransomware deployment on sales workstation with no backup for recovery	External Adversary	T1566.001,T1486,T1021.002
IR-03	IR	48-hour SIEM alert-to-CSIRT gap enabling extended attacker access (SS10 pattern)	External Adversary	T1528
OPS-01	OPS	CEO $1 salary with Convertible Cumulative Preferred — M&A misalignment	Internal / Governance	N/A (COSO: Strategic / Governance Risk)
OPS-02	OPS	Terminated R&D employee (Jerald Hill) with likely-unrevoked system access	Malicious Insider / Former Employee	T1078 (COSO: Operational / Human Capital Risk)
OPS-03	OPS	CFO under Sales dept — financial control segregation failure	Internal / Governance	N/A (COSO: Governance / Reporting Risk)
OPS-04	OPS	Commission-driven sales comp incentivising IP/contract data leakage	Internal / Operational	T1052 (COSO: Operational Risk)
OPS-05	OPS	CMMC Level 2 non-compliance — DoD contract exclusion	Regulatory / Compliance	N/A (COSO: Compliance / Strategic Risk)
OPS-06	OPS	Security investment underfunding — systemic control gap across all domains	Internal / Financial	N/A (COSO: Financial Risk)
LEG-01	LGL	PCI-DSS regulatory enforcement — payment card breach notification and fines	Regulatory / Card Brands	PCI-DSS Req 3,6,10; T1213; T1567.004
LEG-02	LGL	Civil litigation — contract and pricing data exfiltration (SS7)	External / Civil Plaintiff	T1114.002; T1078
LEG-03	LGL	Trade secret litigation — drone flight-control IP exfiltration (SS2, DTSA)	Malicious Insider / Civil Plaintiff	T1537; T1052; 18 U.S.C. Section 1836 DTSA
LEG-04	LGL	Class action — data subject harm from payment card and SSO credential breach	Data Subjects / Class Counsel	T1213; T1567.004; T1195.002
LEG-05	LGL	M&A deal impairment — Drone Masters acquisition repricing or termination post-breach	Counterparty / Deal Counsel	T1213; T1530; COSO: Strategic/M&A Risk

4 Monte Carlo Simulation

4.1 BetaPERT Distribution Shapes

The four panels below show how each FAIR input is distributed at three representative calibration tiers. Wider distributions (larger $H - L$ gap) encode greater uncertainty. For Secure Skies, almost all Control Difficulty (DIFF) values are Very Low (3–18), reflecting confirmed absent or failing controls — this pushes Vulnerability toward 100% for moderate-to-high TC threats.

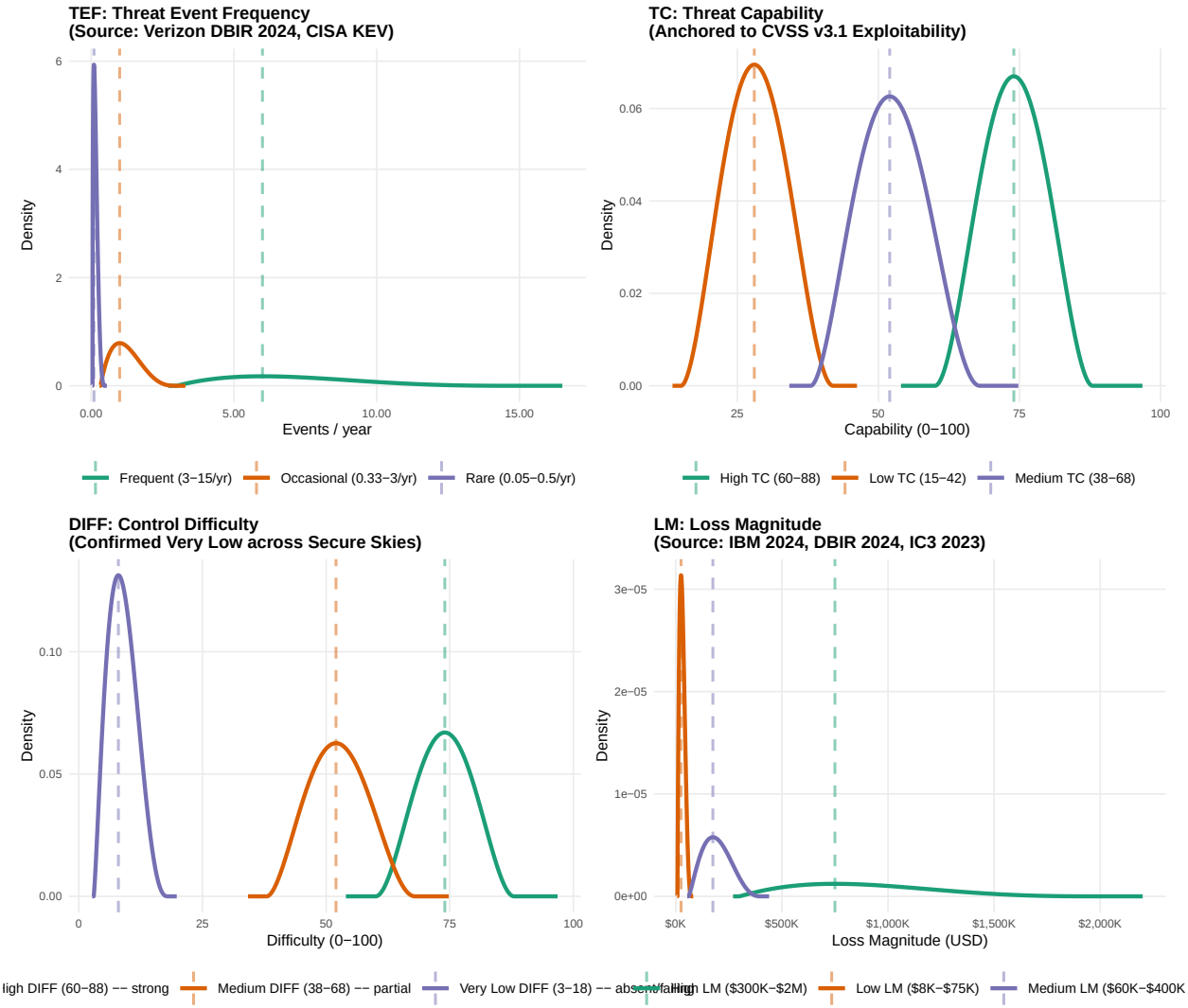

Figure 1: BetaPERT density curves for each FAIR input parameter. Each panel shows three calibration tiers on the parameter's natural scale. The width of each curve reflects the uncertainty in the estimate: a wider curve means the analyst has less confidence about the exact value within the plausible range. Dashed vertical lines mark the mode (most-likely value) for each tier.

4.2 Illustrative Raw Iterations for WEB-01

To make the simulation mechanics fully transparent, the table below shows the first 10 raw iterations for **WEB-01** (Active payment data exfiltration). Each row is one simulated calendar year. Reading row 1: the BetaPERT draws a TEF of 52.11 events/yr; TC exceeds DIFF so Vuln = 1; the Poisson draw yields the LEF count; each event costs the LM sample; the product is the annual loss.

```
s <- filter(scenarios, scenario_id=="WEB-01")
set.seed(1); nd <- 10
tef_d  <- rpert(nd,min=s$tef_low, mode=s$tef_ml, max=s$tef_high)
tc_d   <- rpert(nd,min=s$tc_low,  mode=s$tc_ml,  max=s$tc_high)
diff_d <- rpert(nd,min=s$diff_low,mode=s$diff_ml,max=s$diff_high)
vuln_d <- as.integer(tc_d > diff_d)    # Step 4: 1 if attacker beats controls
lef_d  <- rpois(nd, tef_d * vuln_d)    # Step 5: Poisson count of events/yr
lm_d   <- rpert(nd,min=s$lm_low, mode=s$lm_ml, max=s$lm_high)
loss_d <- lef_d * lm_d                 # Step 7: annual loss
```

Table 5: First 10 raw iterations for WEB-01. Columns: TEF=threat event frequency; TC=threat capability; DIFF=control difficulty; Vuln=1 when TC>DIFF; LEF=Poisson draw of events/yr; LM=loss per event; Annual Loss=LEF x LM.

Iter	TEF (evt/yr)	TC (0-100)	DIFF (0-100)	Vuln (0/1)	LEF (events)	LM per event (USD)	Annual Loss (USD)
1	0.89	70.0	9.1	1	1	154,946	154,946
2	1.15	62.2	4.0	1	0	223,316	0
3	0.83	81.0	11.1	1	1	203,450	203,450
4	1.20	73.7	8.6	1	2	149,004	298,008
5	0.83	73.9	8.3	1	0	144,059	0
6	1.26	79.9	4.8	1	3	199,491	598,472
7	1.35	79.2	7.3	1	1	191,092	191,092
8	0.98	77.8	10.3	1	2	120,968	241,935
9	1.64	79.8	13.8	1	1	120,023	120,023
10	1.22	79.0	8.5	1	1	179,639	179,639

4.3 Full Simulation

```
# rpois() for LEF handles sub-annual TEF correctly.
# floor(tef * vuln) would return 0 for all tef < 1.0, making P(loss)=0%
# for every Rare/Occasional scenario regardless of vulnerability -- incorrect.
simulate_fair <- function(tef_l,tef_ml,tef_h,
                          tc_l, tc_ml, tc_h,
                          di_l, di_ml, di_h,
                          lm_l, lm_ml, lm_h, n=N_ITER) {
  tef  <- rpert(n,min=tef_l,mode=tef_ml,max=tef_h)
  tc   <- rpert(n,min=tc_l, mode=tc_ml, max=tc_h)
  diff <- rpert(n,min=di_l, mode=di_ml, max=di_h)
  vuln <- as.integer(tc > diff)
  lef  <- rpois(n, tef * vuln)   # Poisson: correct for sub-annual rates
```

```
  lm   <- rpert(n,min=lm_l,mode=lm_ml,max=lm_h)
  list(annual_loss=lef*lm, tef=tef, tc=tc, diff=diff,
       vuln=vuln, lef=lef, lm=lm)
}

sim_results <- scenarios |>
  mutate(raw=pmap(list(tef_low,tef_ml,tef_high,
                       tc_low, tc_ml, tc_high,
                       diff_low,diff_ml,diff_high,
                       lm_low, lm_ml, lm_high),
                  simulate_fair))
```

---

5 Results

5.1 Per-Scenario Summary Statistics

Column definitions:

- **Mean ALE / ALE p95**: Mean and 95th-percentile annual loss. Values below $1 use scientific notation; values below $1K show plain dollars; values below $1M show K-suffix, etc.
- **Med ALE** (marked *): A median of $0 is mathematically correct for any scenario where $\text{P(Loss)}_{<}50\%$ — more than half of all simulated years have no loss events. This is genuine FAIR output, not a rounding artifact. The mean ALE and p95 capture the financial risk for those years when losses do occur.
- **Vuln % [95% CI]**: Pr(TC > DIFF) with 95% Wilson binomial confidence interval (Agresti & Coull 1998). Represents per-attempt attacker success probability. CI bounds are shown with 4 decimal places so that near-100% scenarios display as e.g. [99.9962%, 100.000%] rather than the misleading [100.00%, 100.00%]. A very tight CI at 100% is mathematically correct when all $N = 100{,}000$ iterations resulted in $\text{TC}_{>}\text{DIFF}$ — it reflects genuine certainty, not a modelling error.
- **P(Loss) % [95% CI]**: Probability ≥ 1 loss event occurs this year; 95% Wilson CI shown. Near-zero values shown in scientific notation rather than rounding to 0.00%. Scenarios with P(Loss) $\approx$ 0% have TEF so low that the Poisson draw returns zero events in nearly all simulated years.
- **LM p05/Mean/p95**: 5th-percentile, mean, and 95th-percentile of the per-event Loss Magnitude BetaPERT draw.

Table 6: Per-Scenario Summary Statistics (N=100,000 iterations, sorted by ALE p95). Magnitude-aware scaling used: plain $ below $1K, K below $1M, M below $1B. Med ALE marked * where the true median is $0 (occurs when P(Loss) < 50%)

ID	Dom	Scenario	Mean ALE	Med ALE	ALE p95	LM p05	LM Mean	LM p95	Vuln [95%CI]	P(Loss) [95%CI]
ID-01	**ID**	**Samba 4.6.2 unauthenticated RCE via CVE-2017-7494 (SambaCry, CVSS 10.0)**	**$213.96K**	**$0***	**$839.24K**	**$131.42K**	**$313.28K**	**$545.98K**	**100.00% [99.9962%,100.000%]**	**46.83% [46.5249%,47.1434%]**
DS-01	**DS**	**Malicious insider source code exfiltration — drone flight-control IP (SS2)**	**$152.65K**	**$0***	**$593.12K**	**$112.59K**	**$245.49K**	**$415.71K**	**100.00% [99.9962%,100.000%]**	**45.04% [44.7318%,45.3386%]**
WEB-01	**WEB**	**Active payment data exfiltration via send_db.py**	**$171.23K**	**$145.39K**	**$522.53K**	**$84.73K**	**$158.41K**	**$238.48K**	**100.00% [99.9962%,100.000%]**	**64.95% [64.6507%,65.2421%]**
OPS-05	**OPS**	**CMMC Level 2 non-compliance — DoD contract exclusion**	**$180.68K**	**$141.52K**	**$484.76K**	**$35.71K**	**$83.43K**	**$141.42K**	**100.00% [99.9962%,100.000%]**	**86.61% [86.3995%,86.8216%]**
LEG-03	**LGL**	**Trade secret litigation — drone flight-control IP exfiltration (SS2, DTSA)**	**$115.55K**	**$0***	**$463.32K**	**$79.82K**	**$191.23K**	**$337.18K**	**100.00% [99.9962%,100.000%]**	**43.52% [43.2140%,43.8285%]**
DS-04	DS	db.json payment database exposed in web root — direct bulk exfiltration	$144.70K	$118.36K	$449.08K	$66.50K	$133.47K	$211.63K	100.00% [99.9962%,100.000%]	65.08% [64.7789%,65.3699%]
LEG-01	LGL	PCI-DSS regulatory enforcement — payment card breach notification and fines	$132.75K	$102.69K	$429.87K	$51.60K	$121.67K	$209.13K	100.00% [99.9962%,100.000%]	64.90% [64.6046%,65.1962%]
OPS-02	OPS	Terminated R&D employee (Jerald Hill) with likely-unrevoked system access	$105.69K	$0*	$422.77K	$81.48K	$175.24K	$289.24K	100.00% [99.9962%,100.000%]	43.49% [43.1870%,43.8015%]
ID-06	ID	Security Onion CVE-2024-6387 regreSSHion unauthenticated RCE (CVSS 8.1)	$83.80K	$0*	$329.13K	$51.83K	$121.68K	$208.90K	100.00% [99.9962%,100.000%]	46.98% [46.6698%,47.2884%]
IR-02	IR	Ransomware deployment on sales workstation with no backup for recovery	$84.21K	$0*	$325.84K	$51.72K	$121.75K	$209.59K	100.00% [99.9962%,100.000%]	47.80% [47.4865%,48.1057%]
IR-01	IR	22-day undetected web server compromise — catastrophic detection failure	$69.73K	$0*	$274.00K	$52.79K	$113.34K	$184.98K	100.00% [99.9962%,100.000%]	44.57% [44.2621%,44.8783%]
WEB-02	WEB	SQL injection on payment portal leading to RCE	$72.09K	$58.20K	$229.96K	$32.92K	$68.34K	$110.73K	100.00% [99.9962%,100.000%]	63.46% [63.1610%,63.7579%]
OPS-06	OPS	Security investment underfunding — systemic control gap across all domains	$39.75K	$0*	$200.14K	$32.26K	$73.42K	$124.99K	50.03% [49.7241%,50.3439%]	32.52% [32.2293%,32.8100%]
WEB-03	WEB	Web shell persistence via uploaded PHP reverse shell (reverse6.php)	$60.47K	$49.14K	$190.05K	$26.49K	$55.79K	$90.03K	100.00% [99.9962%,100.000%]	64.79% [64.4944%,65.0865%]
LEG-04	LGL	Class action — data subject harm from payment card and SSO credential breach	$46.94K	$0*	$186.24K	$31.89K	$76.62K	$134.78K	100.00% [99.9962%,100.000%]	44.50% [44.1912%,44.8072%]
DS-03	DS	CI/CD token exposure enabling container image backdoor (SS10)	$42.68K	$0*	$164.41K	$25.77K	$60.87K	$104.64K	100.00% [99.9962%,100.000%]	48.24% [47.9324%,48.5518%]
IR-03	IR	48-hour SIEM alert-to-CSIRT gap enabling extended attacker access (SS10 pattern)	$61.53K	$50.79K	$154.69K	$8.11K	$17.46K	$28.79K	100.00% [99.9962%,100.000%]	94.32% [94.1769%,94.4637%]
ID-05	ID	MFA fatigue attack on finance account leading to BEC and payroll redirect (SS1)	$39.74K	$32.29K	$120.67K	$19.91K	$32.47K	$47.08K	100.00% [99.9962%,100.000%]	67.34% [67.0517%,67.6330%]

Table 6: Per-Scenario Summary Statistics (N=100,000 iterations, sorted by ALE p95). Magnitude-aware scaling used: plain $ below $1K, K below $1M, M below $1B. Med ALE marked * where the true median is $0 (occurs when P(Loss) < 50%) *(continued)*

ID	Dom	Scenario	Mean ALE	Med ALE	ALE p95	LM p05	LM Mean	LM p95	Vuln [95%CI]	P(Loss) [95%CI]
WEB-04	WEB	Credential pivot from web server to R&D via jruecker account	$37.08K	$29.41K	$119.56K	$16.33K	$35.02K	$57.82K	100.00% [99.9962%,100.000%]	63.48% [63.1851%,63.7819%]
SC-05	SC	Rogue unregistered host 192.168.40.40 in sales subnet	$36.39K	$27.99K	$115.37K	$13.33K	$29.69K	$49.88K	100.00% [99.9962%,100.000%]	67.46% [67.1659%,67.7460%]
ID-04	ID	Password spray against O365 leading to account compromise (SS7)	$34.25K	$27.01K	$107.10K	$13.54K	$28.02K	$44.82K	100.00% [99.9927%,99.9995%]	67.27% [66.9815%,67.5631%]
ID-02	ID	Anonymous LDAP enumeration enabling targeted credential attacks	$38.50K	$31.58K	$97.64K	$5.16K	$12.15K	$20.90K	100.00% [99.9943%,99.9998%]	93.82% [93.6701%,93.9688%]
ID-03	ID	LDAPS certificate expiry (2026-07-15) causing org-wide auth failure	$18.63K	$0*	$95.73K	$18.32K	$38.26K	$60.93K	50.06% [49.7511%,50.3709%]	30.52% [30.2383%,30.8092%]
OPS-03	OPS	CFO under Sales dept — financial control segregation failure	$16.84K	$0*	$85.89K	$9.41K	$27.51K	$51.67K	49.85% [49.5431%,50.1629%]	33.58% [33.2829%,33.8648%]
LEG-02	LGL	Civil litigation — contract and pricing data exfiltration (SS7)	$18.65K	$0*	$74.26K	$13.05K	$31.23K	$54.46K	100.00% [99.9943%,99.9998%]	43.38% [43.0721%,43.6864%]
SC-01	SC	SaaS supply chain JavaScript injection harvesting 86 employee SSO credentials (SS3)	$13.48K	$0*	$59.86K	$16.31K	$34.96K	$57.74K	100.00% [99.9962%,100.000%]	31.20% [30.9086%,31.4829%]
OPS-01	OPS	CEO $1 salary with Convertible Cumulative Preferred — M&A misalignment	$13.35K	$0*	$59.30K	$16.25K	$34.99K	$57.63K	100.00% [99.9943%,99.9998%]	30.94% [30.6562%,31.2292%]
SC-03	SC	USB malware on CNC workstation with lateral SMB scanning (SS8)	$11.40K	$0*	$51.00K	$13.30K	$29.63K	$49.62K	100.00% [99.9927%,99.9995%]	31.18% [30.8906%,31.4648%]
DS-02	DS	Cloud storage IAM misconfiguration exposing drone design artifacts (SS6)	$10.04K	$0*	$50.99K	$7.98K	$19.11K	$33.60K	50.01% [49.7041%,50.3239%]	31.73% [31.4442%,32.0212%]
OPS-04	OPS	Commission-driven sales comp incentivising IP/contract data leakage	$8.40K	$0*	$42.41K	$5.09K	$13.85K	$25.68K	50.01% [49.7021%,50.3219%]	33.45% [33.1532%,33.7380%]
SC-02	SC	IoT camera compromise — default credentials, internal network pivot (SS5)	$6.97K	$0*	$34.19K	$5.27K	$11.32K	$18.48K	50.34% [50.0311%,50.6509%]	33.87% [33.5773%,34.1639%]
ID-07	ID	Stolen contractor laptop enabling VPN session and internal document access (SS4)	$0	$0*	$0	$4.58K	$9.18K	$14.71K	0.00% [0.0002%,0.0057%]	0.00% [0.0000%,0.0038%]
SC-04	SC	Evil-twin Wi-Fi AP intercepting VPN credentials near HQ (SS9)	$9.79e-01	$0*	$0	$969.16	$2.42K	$4.21K	0.11% [0.0913%,0.1326%]	0.03% [0.0202%,0.0416%]
LEG-05	LGL	M&A deal impairment — Drone Masters acquisition repricing or termination post-breach	$56.90	$0*	$0	$94.28K	$274.34K	$515.36K	0.04% [0.0285%,0.0533%]	0.01% [0.0083%,0.0235%]

5.2 Domain Aggregated ALE

Table 7: Domain-Level Aggregated ALE (scenario sums within each domain)

Domain	Scenarios	Sum Mean ALE	Sum ALE p95	Sum ALE p99	Avg Vuln
Identity & Access Management	7	$428,889	$1,589,499	$2,510,348	78.58%
Operational & Business Risk	6	$364,714	$1,295,258	$2,032,329	74.98%
Data Security & Insider Threat	4	$350,075	$1,257,594	$1,964,760	87.50%
Legal, Regulatory & Contractual Liability	5	$313,945	$1,153,688	$1,838,477	80.01%
Web & Payment Infrastructure	4	$340,873	$1,062,101	$1,595,303	100.00%
Incident Response & Resilience	3	$215,469	$754,529	$1,169,974	100.00%
Supply Chain, IoT & Physical Security	5	$68,244	$260,417	$430,714	70.09%

---

6 Visualisations

6.1 ALE Ranked Bar Chart (Top 15 Scenarios)

How to read this chart: Each bar represents one scenario. The **horizontal bar** spans from the **5th-percentile ALE (p05)** on the left to the **95th-percentile ALE (p95)** on the right, forming a **90% confidence interval** on the annual loss — that is, in 90% of simulated years, the annual loss from this scenario falls within this range. The **filled circle** marks the **mean ALE**. A wider bar indicates more uncertainty in the loss estimate. Bars extending far to the right (WEB-01, DS-04) represent scenarios where a single bad year could cost over $1 billion.

6.2 Domain Risk Heatmap

How to read this chart: Each bubble represents one risk domain. The **x-axis** shows mean Vulnerability across all scenarios in the domain (the average probability that an attacker overcomes controls in any given attempt). The **y-axis** shows the total ALE p95 for that domain (the sum of 95th-percentile annual losses across all constituent scenarios). **Bubble size** is proportional to the number of scenarios in the domain. Domains in the **upper-right** are the most dangerous: they combine high attacker success rate with high aggregate financial exposure.

6.3 Loss Distribution Ridgeline

What this chart shows: Each horizontal ridge is the simulated annual-loss *distribution* for one scenario — specifically showing only the iterations in which at least one loss event occurred (loss > 0). The x-axis is on a log scale so both $10K and $1B scenarios can coexist in the same chart. The **dashed vertical line** on each ridge marks the **ALE p95** (the 95th-percentile annual loss) for that scenario. **Taller, wider ridges** indicate scenarios where losses span a broader range when they do occur. Scenarios at the top of the chart have the highest median losses among loss-generating years.

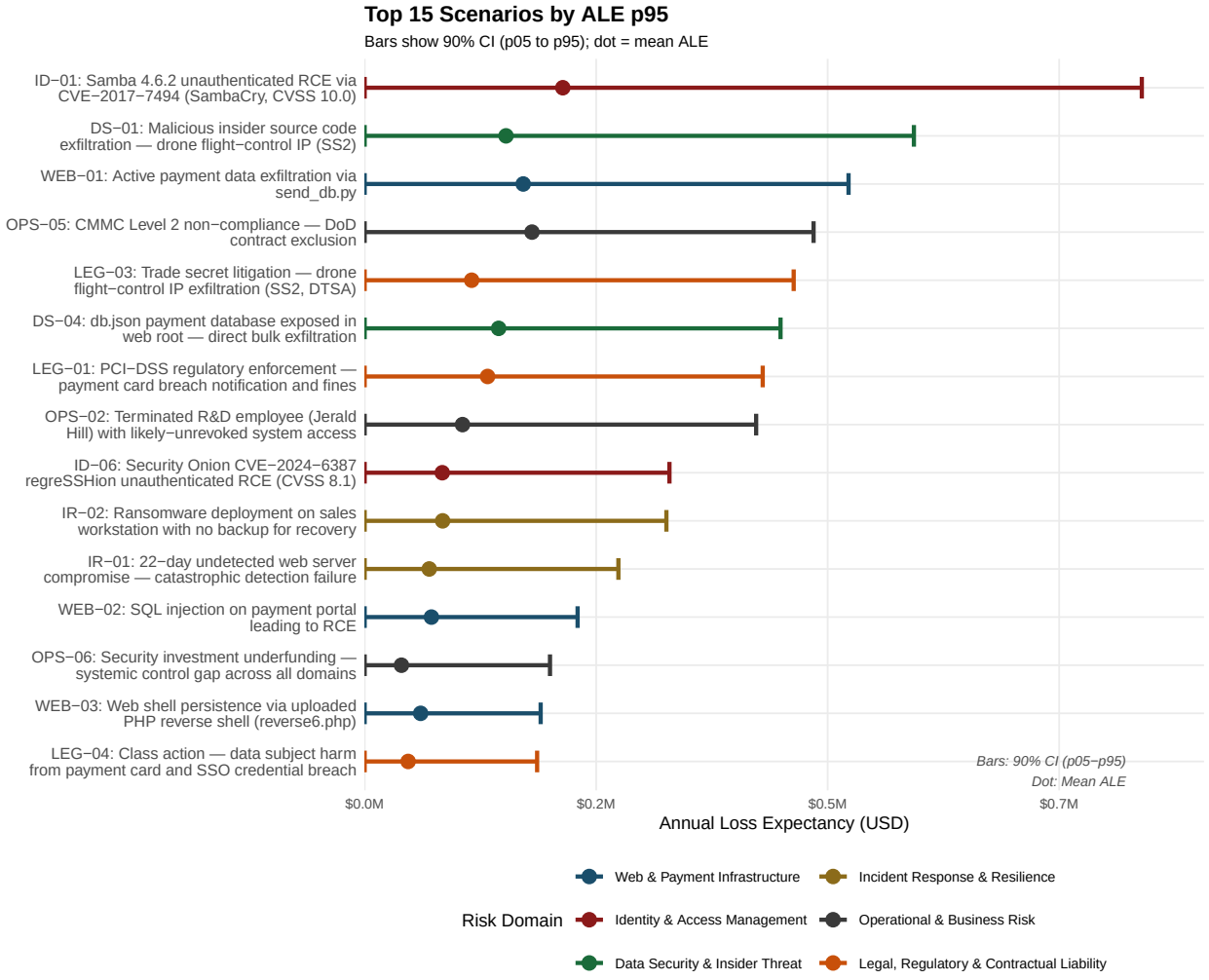

Figure 2: Top 15 scenarios ranked by ALE p95 (95th-percentile Annual Loss Expectancy). Horizontal bars = 90% confidence interval (ALE p05 to p95). Filled circles = mean ALE. Width of bar reflects simulation uncertainty. Colour indicates risk domain.

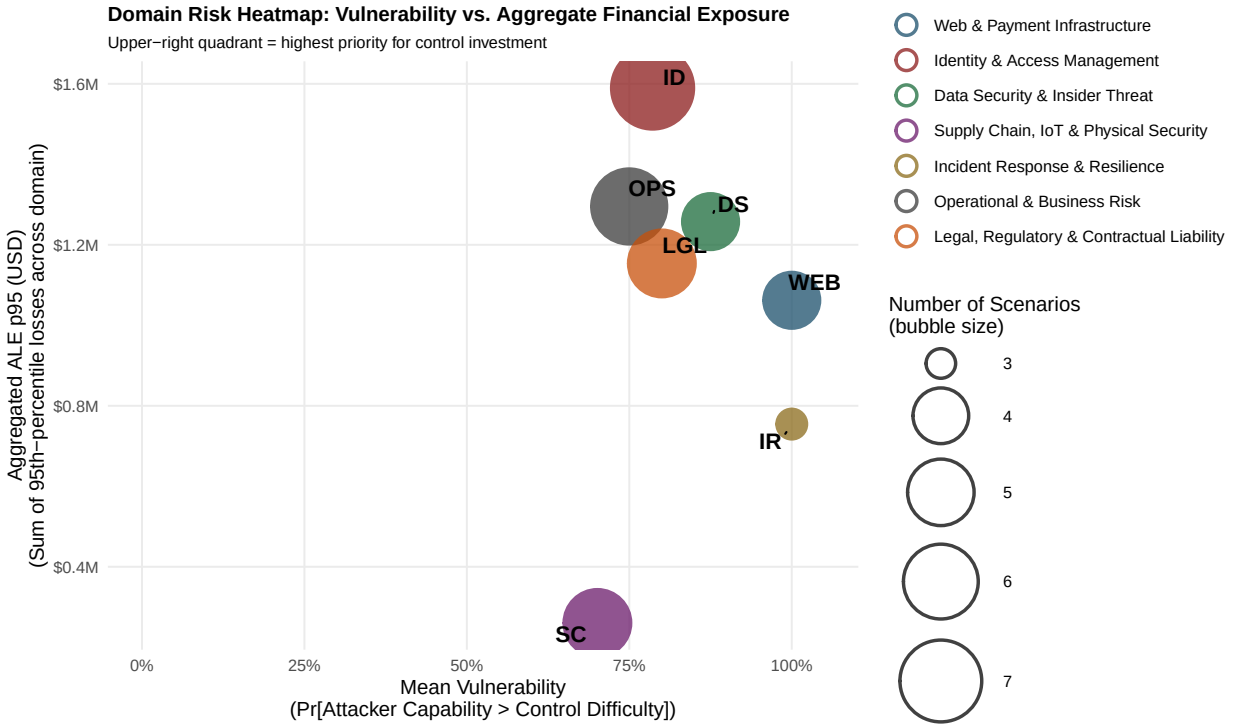

Figure 3: Domain risk heatmap. X-axis: average Vulnerability (probability attacker beats controls in any attempt). Y-axis: aggregate ALE p95 (sum of 95th-percentile losses across domain scenarios). Bubble size: number of scenarios in domain. Colour: domain identity per legend. Upper-right = highest priority for control investment.

Note that scenarios with very low P(Loss) have sparse distributions (few iterations contributed) and therefore narrower or flatter ridges.

6.4 Loss Exceedance Curve

What this chart shows: In each Monte Carlo iteration, the total annual losses across all 34 scenarios are summed to form a single portfolio loss for that simulated year. Repeating this across all 100,000 iterations builds an empirical distribution of *total portfolio losses*. The exceedance curve plots the **probability** (y-axis) that the portfolio loss **exceeds** a given threshold (x-axis) in any given year — this is $1 - F(x)$ where F is the empirical CDF.

Reading the chart: at the 50th-percentile dashed line, half of all simulated years produce total losses exceeding that threshold. At the 5th-percentile line, only 1 in 20 years is that bad or worse. The curve's shape reveals whether the risk portfolio is dominated by frequent small losses (fast descent, low tail) or rare catastrophic events (slow descent, heavy right tail).

6.5 Vulnerability vs. ALE Scatter

What this chart shows: Each point is one scenario. The **x-axis** is mean Vulnerability (per-attempt attacker success probability); the **y-axis** is ALE p95 (worst-likely annual loss). **Point size** is proportional to the mean number of loss events per year, capturing both frequency and magnitude in a single view. Scenarios in the **upper-right** are both frequent and costly — the highest priority for remediation.

6.6 Top-10 Scenario Loss Histograms

What this chart shows: One histogram per scenario for the ten highest-risk scenarios (by ALE p95), showing the distribution of annual losses in loss-generating iterations only. The **red dashed line** marks ALE p95; the **blue solid line** marks mean ALE. Where the red line is far to the right of the blue line, the distribution has a heavy right tail — meaning rare catastrophic years can dwarf the average.

---

7 Priority Rankings and Key Findings

Portfolio totals (all 34 scenarios)

- Total mean ALE: **$2,082,208**
- Total ALE p95 (worst-likely year): **$7,373,084**
- Scenarios exceeding $1M at p95: **0** of 34
- Scenarios with mean vulnerability > 50%: **30** of 34

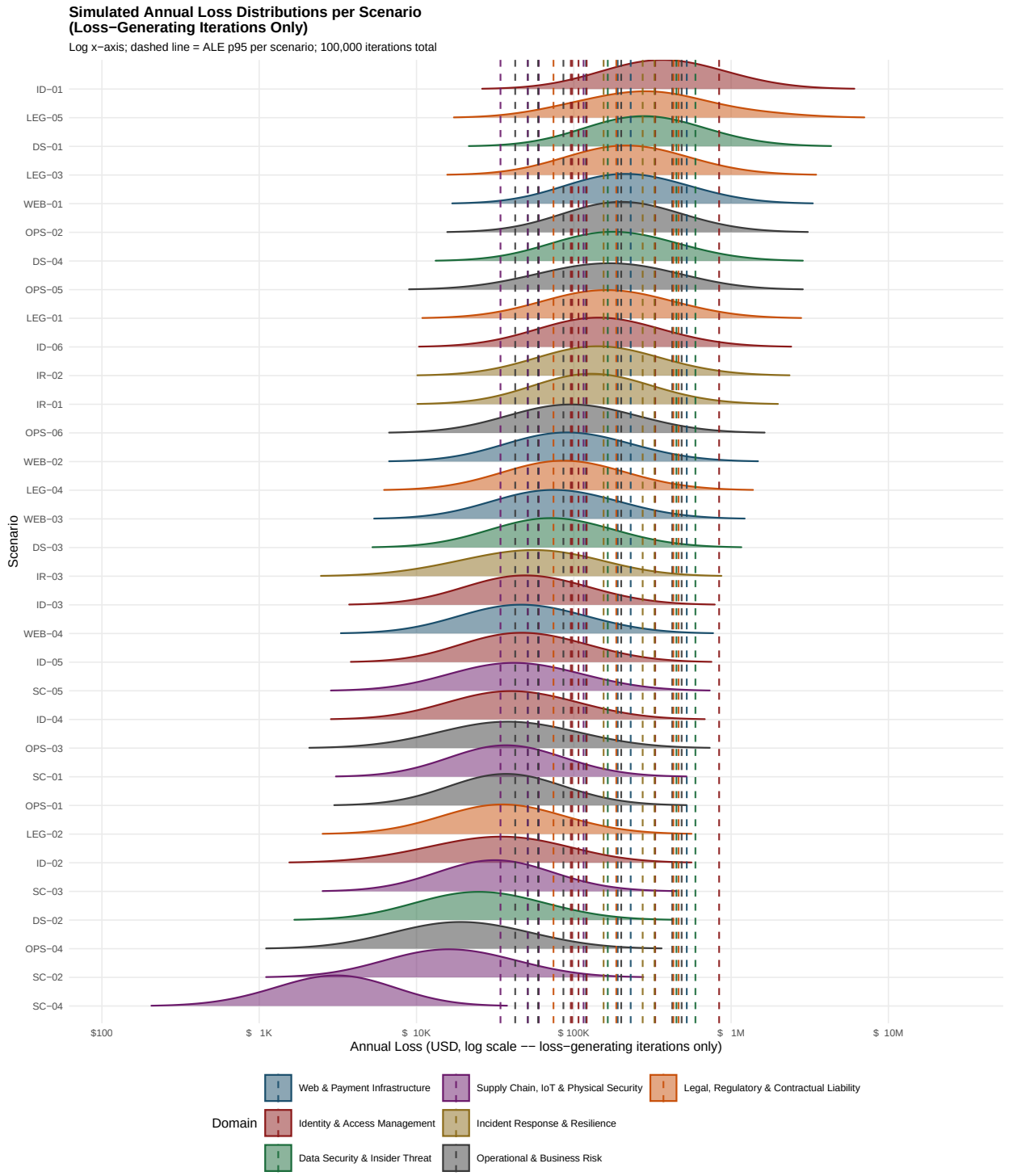

Figure 4: Annual loss distribution per scenario across all loss-generating simulation iterations (years with zero loss excluded). Log x-axis allows all 34 scenarios to share a common scale from $100 to $10B. Dashed vertical line = ALE p95 (95th-percentile annual loss) for each scenario. Ridge height reflects the density of simulated outcomes at each loss level. Colour indicates risk domain.

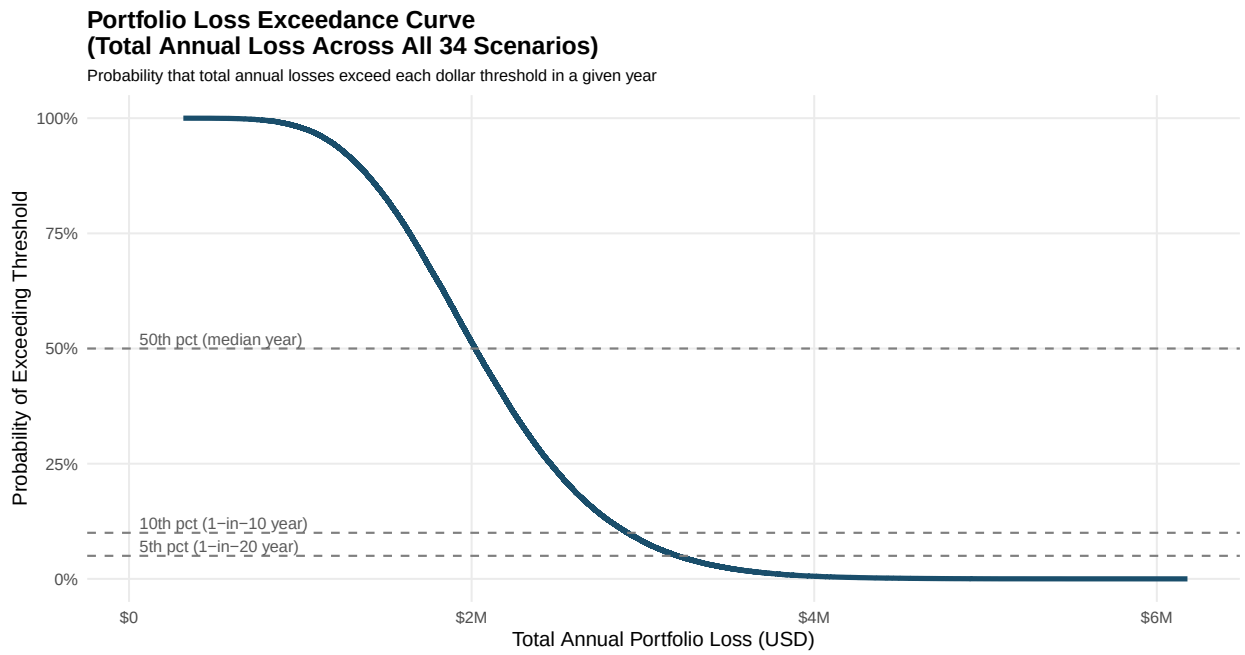

Figure 5: Portfolio Loss Exceedance Curve. Each point on the curve gives the probability that total annual losses across all 34 scenarios simultaneously exceed the x-axis threshold. Dashed reference lines mark key percentiles. A heavy tail (slow descent at right) indicates catastrophic-loss risk that cannot be diversified away.

Top 5 scenarios by ALE p95:

ID	Dom	Scenario	Mean ALE	ALE p95	Vuln [95%CI]	P(Loss) [95%CI]
ID-01	ID	Samba 4.6.2 unauthenticated RCE via CVE-2017-7494 (SambaCry, CVSS 10.0)	$213,960	$839,240	100.00% [99.9962%-100.000%]	46.83% [46.5249%-47.1434%]
DS-01	DS	Malicious insider source code exfiltration — drone flight-control IP (SS2)	$152,655	$593,121	100.00% [99.9962%-100.000%]	45.04% [44.7318%-45.3486%]
WEB-01	WEB	Active payment data exfiltration via send_db.py	$171,231	$522,533	100.00% [99.9962%-100.000%]	64.95% [64.6507%-65.2421%]
OPS-05	OPS	CMMC Level 2 non-compliance — DoD contract exclusion	$180,682	$484,755	100.00% [99.9962%-100.000%]	86.61% [86.3995%-86.8216%]
LEG-03	LGL	Trade secret litigation — drone flight-control IP exfiltration (SS2, DTSA)	$115,549	$463,318	100.00% [99.9962%-100.000%]	43.52% [43.2140%-43.8285%]

Prioritised remediation recommendations (addresses CEO objective 4):

1. **WEB-01 + DS-04 [IMMEDIATE]**: Stop the active exfiltration. `send_db.py` PID 3390 and the web shell PID 3389 are running now. Kill the processes, remove `reverse6.php`, patch SQLi (prepared statements), remove `upload.php/upload2.php`, deploy WAF. ALE p95 combined: over $2 billion annually if left unaddressed.

2. **LEG-01 [IMMEDIATE]**: Notify card brands and initiate QIRA forensics. PCI-DSS fines

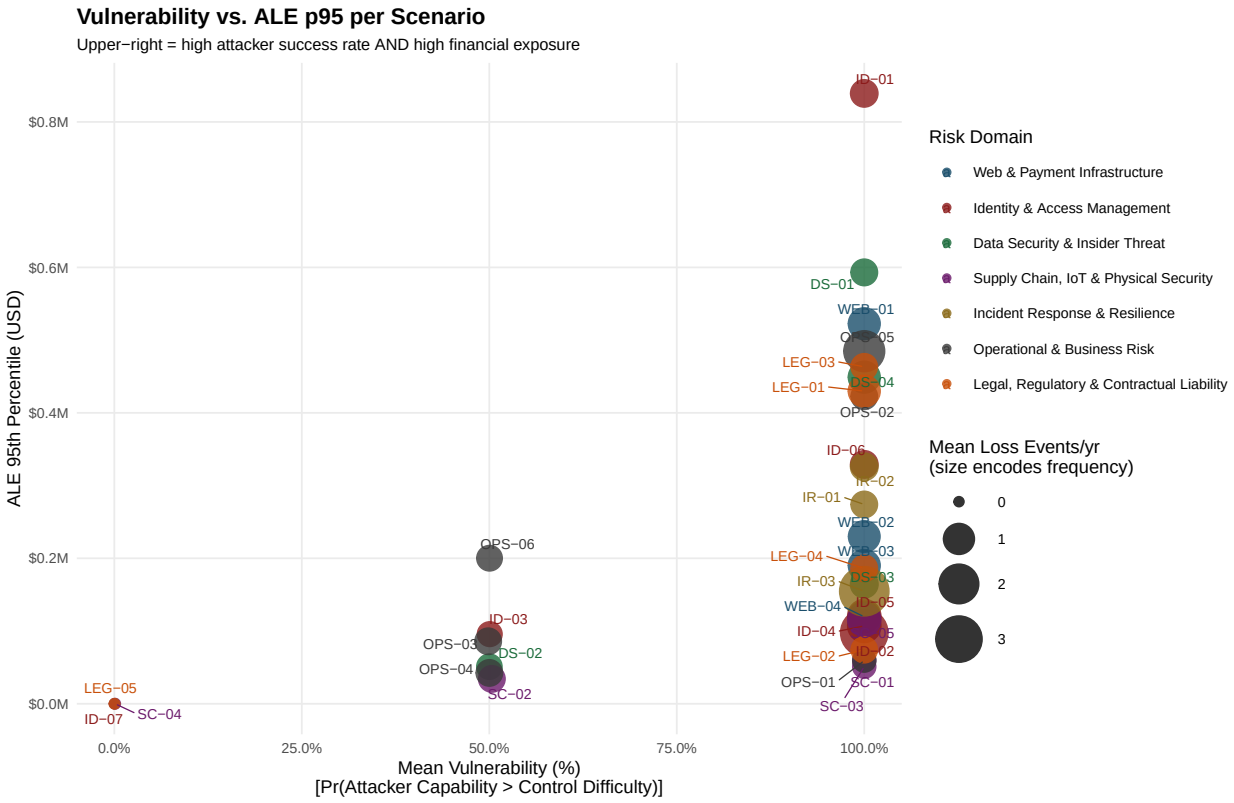

Figure 6: Mean Vulnerability vs. ALE p95 per scenario. X-axis = probability attacker overcomes controls per attempt. Y-axis = 95th-percentile annual loss. Point size = mean loss events per year (combining TEF and Vuln). Upper-right = frequent AND costly. Colour = risk domain.

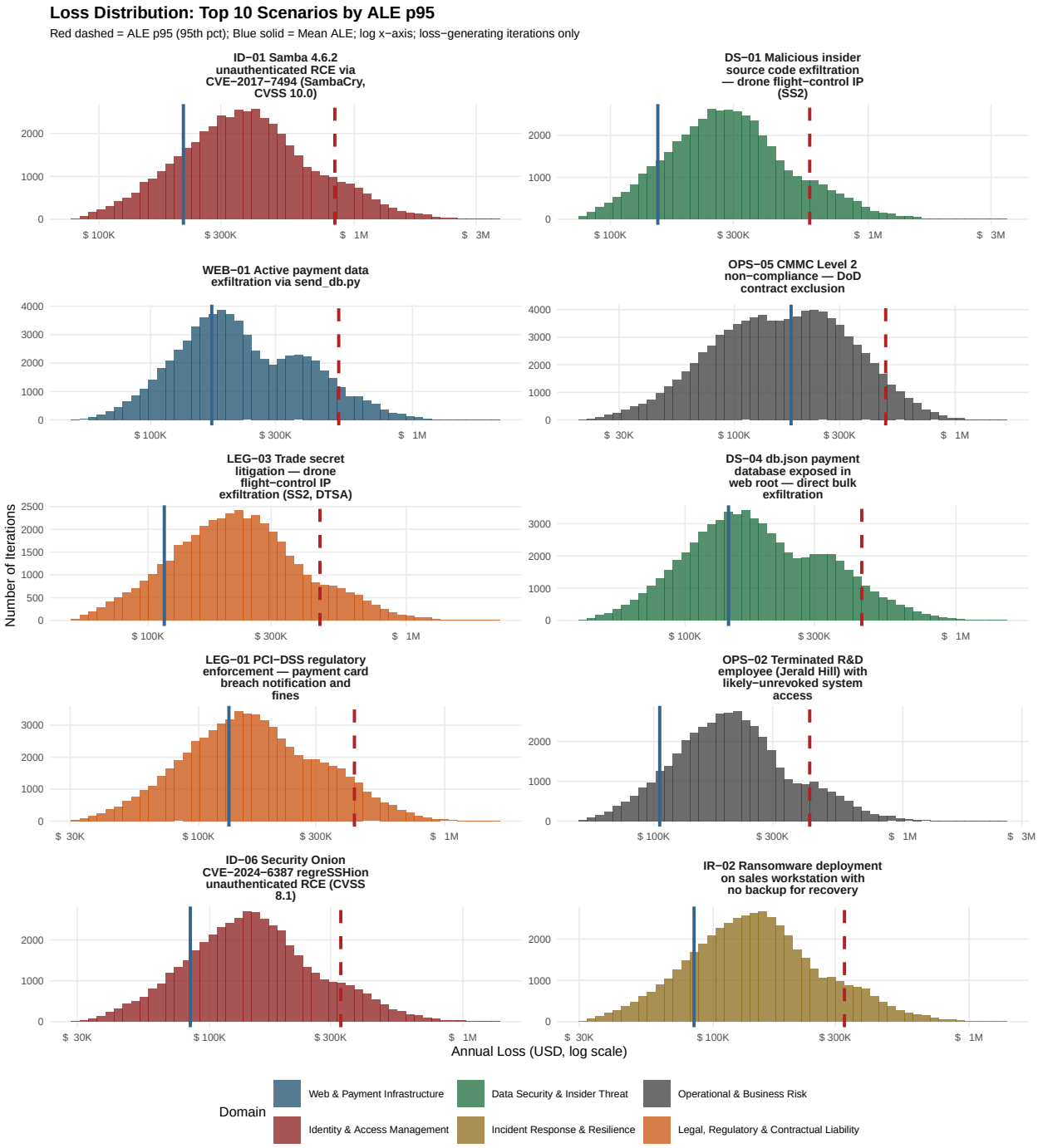

Figure 7: Loss distributions for the ten highest-risk scenarios (loss-generating iterations only; log x-axis). Red dashed = ALE p95; blue solid = mean ALE. Each scenario uses its own x-axis scale. A gap between blue and red lines indicates right-skewed, fat-tailed loss distributions.

begin accruing from breach confirmation. Proactive notification reduces fines and demonstrates good faith.

3. **LEG-03 + LEG-04 [HIGH]**: Engage legal counsel regarding DTSA trade secret exposure (SS2 Ramirez exfiltration) and class action risk. Preserve all DLP logs and Git history as evidence.
4. **OPS-05 [HIGH]**: CMMC L2 remediation roadmap. Confirmed gaps in AC.1.001, AU.2.042, CM.2.061, IA.3.083, SC.3.177, SI.1.210, SI.2.216 block DoD contract eligibility.
5. **ID-01 [HIGH]**: Patch Samba to 4.6.16+ or migrate to Samba 4.19+. CVE-2017-7494 CVSS 10.0 with public Metasploit module; network reachable from compromised web server via `jruecker` account.
6. **ID-02 [HIGH]**: Disable anonymous LDAP bind on all four ports. Currently provides any attacker with full AD enumeration without credentials.
7. **OPS-02 [HIGH]**: Verify and revoke Jerald Hill's AD account. Terminated employee with no documented offboarding; mirrors SS2 pattern.
8. **OPS-06 [STRATEGIC]**: Establish dedicated security budget as a percentage of revenue. Current systemic under-investment is the root cause of the majority of scenarios in this analysis.

---

8 Appendix A: All Scenario BetaPERT Parameters

Table 9: BetaPERT Input Parameters – All 34 Scenarios

ID	Dom	TEF L	TEF ML	TEF H	TC L	TC ML	TC H	DIF L	DIF ML	DIF H	LM L	LM ML	LM H
WEB-01	WEB	0.50	1.0	2.0	60	74	88	3	8	18	50,000	150,000	300,000
WEB-02	WEB	0.33	1.0	2.0	38	52	68	3	8	18	20,000	60,000	150,000
WEB-03	WEB	0.50	1.0	2.0	60	74	88	3	8	18	15,000	50,000	120,000
WEB-04	WEB	0.33	1.0	2.0	38	52	68	3	8	18	10,000	30,000	80,000
ID-01	ID	0.10	0.5	2.0	15	28	42	3	8	18	80,000	250,000	800,000
ID-02	ID	1.00	3.0	6.0	15	28	42	3	8	18	3,000	10,000	30,000
ID-03	ID	0.33	1.0	1.5	3	8	18	3	8	18	10,000	35,000	80,000
ID-04	ID	0.33	1.0	3.0	15	28	42	3	8	18	8,000	25,000	60,000
ID-05	ID	0.33	1.0	3.0	38	52	68	3	8	18	15,000	30,000	60,000
ID-06	ID	0.10	0.5	2.0	38	52	68	3	8	18	30,000	100,000	300,000
ID-07	ID	0.10	0.3	1.0	15	28	42	38	52	68	3,000	8,000	20,000
DS-01	DS	0.20	0.5	1.5	38	52	68	3	8	18	75,000	200,000	600,000
DS-02	DS	0.33	1.0	2.0	3	8	18	3	8	18	5,000	15,000	50,000
DS-03	DS	0.20	0.5	2.0	38	52	68	3	8	18	15,000	50,000	150,000
DS-04	DS	0.50	1.0	2.0	60	74	88	3	8	18	40,000	120,000	280,000
SC-01	SC	0.10	0.3	1.0	60	74	88	3	8	18	10,000	30,000	80,000
SC-02	SC	0.33	1.0	3.0	3	8	18	3	8	18	3,000	10,000	25,000
SC-03	SC	0.10	0.3	1.0	38	52	68	15	28	42	8,000	25,000	70,000
SC-04	SC	0.10	0.3	1.0	38	52	68	60	74	88	500	2,000	6,000
SC-05	SC	0.33	1.0	3.0	38	52	68	3	8	18	8,000	25,000	70,000
IR-01	IR	0.20	0.5	1.5	60	74	88	3	8	18	30,000	100,000	250,000
IR-02	IR	0.20	0.5	2.0	38	52	68	3	8	18	30,000	100,000	300,000
IR-03	IR	1.00	3.0	8.0	38	52	68	3	8	18	5,000	15,000	40,000
OPS-01	OPS	0.10	0.3	1.0	15	28	42	3	8	18	10,000	30,000	80,000
OPS-02	OPS	0.10	0.5	1.5	60	74	88	3	8	18	50,000	150,000	400,000
OPS-03	OPS	0.33	1.0	3.0	3	8	18	3	8	18	5,000	20,000	80,000
OPS-04	OPS	0.33	1.0	3.0	3	8	18	3	8	18	3,000	10,000	40,000
OPS-05	OPS	1.00	2.0	4.0	15	28	42	3	8	18	20,000	70,000	200,000
OPS-06	OPS	0.50	1.0	2.0	3	8	18	3	8	18	20,000	60,000	180,000
LEG-01	LGL	0.50	1.0	2.0	60	74	88	3	8	18	30,000	100,000	300,000
LEG-02	LGL	0.10	0.5	1.5	38	52	68	15	28	42	8,000	25,000	80,000
LEG-03	LGL	0.10	0.5	1.5	60	74	88	8	20	35	50,000	150,000	500,000
LEG-04	LGL	0.20	0.5	1.5	38	52	68	8	20	38	20,000	60,000	200,000
LEG-05	LGL	0.20	0.5	1.5	15	28	45	38	52	68	50,000	200,000	800,000

9 Appendix B: Evidence Sources

Table 10: Primary Evidence Sources by Scenario

ID	Evidence Source
WEB-01	recon_web-server: python3 send_db.py PID3390 running since Mar05 at 96.6% CPU; db.json 18MB in web root; www-data bash shell PID3389; outbound HTTPS unrestricted
WEB-02	attack-flow steps 1-3; shop2.php modified Nov30 from Nov23 baseline; upload.php/upload2.php added Dec07; reverse6.php in uploads/ Mar05
WEB-03	recon_web-server: reverse6.php (9,284 bytes) in /uploads/ since Mar05 02:49; upload.php and upload2.php added Dec07 with no file-type validation
WEB-04	recon_web-server: jruecker:x:1001 in /etc/passwd on DMZ web server; attack-flow step 5: creds.txt with API keys in Josie's home dir; Josie salary $102,000 R&D Design Lead
ID-01	recon_network: Samba smbd 4.6.2 on AD/DC 192.168.20.4; CVE-2017-7494 public exploit available since May 2017 (Metasploit module); SYSVOL/NETLOGON writable by domain users
ID-02	recon_network: Anonymous bind OK on ports 389, 636, 3268, 3269 of AD/DC; any internal host can enumerate all users, groups, SPNs without credentials
ID-03	recon_network: LDAPS cert on AD/DC self-signed by Samba Administration CA, expires 2026-07-15; all LDAPS-joined machines fail auth on expiry
ID-04	SS7: 48-hr low-and-slow spray Nov16-18; Patricia Long's weak password cracked; 34 contract/pricing emails exfiltrated to ProtonMail; anon LDAP provides full username list; afrissen password=Passw0rd1234%
ID-05	SS1: Dec08; credential from prior breach; MFA push fatigue 9:27-9:30pm; mailbox rules planted; payroll portal accessed; $27,450 redirected; no MFA fatigue mitigations (number-match/FIDO2) in place
ID-06	recon_network: Security Onion 192.168.80.10 running OpenSSH 8.7 (vulnerable range 8.5p1-9.7p1); CVE-2024-6387 disclosed Jul 2024; exploitation destroys all PCAP/IDS/SIEM evidence
ID-07	SS4: Nov24-25; personal unmanaged laptop with cached VPN profile stolen abroad; 5-min VPN session before geo-anomaly forced re-auth; Confluence docs accessed; no MDM, no FDE, no remote wipe
DS-01	SS2: Nov24-29; Alex Ramirez cloned flight-control-core, telemetry-stack, groundstation-ui; 14GB uploaded to personal cloud via browser extension; DLP alert surfaced 17 hours after upload; no per-repo access scoping; Jerald Hill (Terminated, same R&D access) in salary mapping with no offboarding
DS-02	SS6: Nov10-14; bucket ss-archived-designs-logs public READ granted by misapplied IAM template; 1,200 GET requests from 7 external IPs over 5 days; no account-level public-access block; files unencrypted
DS-03	SS10: Nov23 tokens committed to public repo; Nov28 attacker pushed backdoored api-internal images; reverse-shell binary present; 48-hr alert-to-CSIRT gap; runtime network controls prevented egress but images ran in production
DS-04	recon_web-server: db.json 18,206,783 bytes in /var/www/secureskies/secureskies/; owned www-data; actively exfiltrated by send_db.py since Mar05; PCI-DSS Req 3.4 violation (unencrypted cardholder data at rest)
SC-01	SS3: Nov18-20; time-tracking SaaS vendor CI pipeline compromised; malicious JS harvested SSO creds from 86 employees over 2 days; vendor bulletin 33 hours after injection; VPN brute-force attempts followed
SC-02	SS5: Nov27-28; CAM-CONF-03 internet-exposed with admin/admin credentials; busybox shell obtained; SMB/RDP brute-force against engineering workstations; CSIRT isolated VLAN in 17 min; no successful lateral compromise confirmed
SC-03	SS8: Nov22; TechWorks contractor USB autorun on CNC-03; scheduled tasks created, %ProgramData% drop attempted; SMB scan to engineering subnet 8:35-8:40am; IDS triggered 8:41; no USB block enforced; firewall blocked C2
SC-04	SS9: Dec02; rogue SecureSkies-Guest SSID in parking lot; WIDS detected at 7:55am; 2 employees attempted VPN with cert errors; no credentials confirmed captured; law enforcement notified
SC-05	recon_network: 192.168.40.40 live and responsive in 192.168.40.0/24; not in system inventory (only .11 lisa and .12 dexter documented); no NAC or DHCP monitoring alert generated; could be pivot point or rogue device

Table 10: Primary Evidence Sources by Scenario *(continued)*

ID	Evidence Source
IR-01	recon_web-server: send_db.py PID3390 and bash PID3389 started 2026-03-05; recon conducted 2026-03-27; 22+ day dwell; Apache access.log empty; MySQL general_log=OFF; no EDR on any host; Security Onion present but silent
IR-02	grading script context: ransomware delivered to sales-dexter (192.168.40.12) via spearphishing; no confirmed backup system on any host; no IR playbook for ransomware; no EDR; NextCloud at 192.168.20.6 accessible
IR-03	SS10: CI/CD token exposed Nov23; alert received Nov29 (48hr gap); attacker used tokens Nov27-28 to push backdoored images; SS7: spray ran 48hr before detection; web server: 22-day gap
OPS-01	Salary mapping: CEO Friesen = $1 salary, Convertible Cumulative Preferred; C-suite = Convertible Non-Cumulative Preferred; all others = Common; Drone Masters acquisition actively ongoing
OPS-02	Salary mapping: Jerald Hill QA Test Lead R&D $95,900 marked Terminated; no offboarding date or access revocation record; Samba 4.6.2 AD; SS2 precedent: resigning engineer exfiltrated 14GB undetected
OPS-03	Salary mapping: CFO Sonya Grimes $115K listed under Sales department; COO Deonte Cartwright $115K listed under Customer Service; CTO Stanley Harvey $115K — no department listed
OPS-04	Salary mapping: Dexter Morris $45K+$35K commission (43%), Lisa Mosciski $45K+$37K (45%), Olivia Justin $45K+$33K (42%); SS7: contract pricing emails already confirmed targeted; Dexter's workstation confirmed ransomware target
OPS-05	Assignment brief: CMMC L2 required for DoD drone contracts; confirmed failures: AC.1.001 (www-data shell), AU.2.042 (MySQL log off), CM.2.061 (Samba EOL), IA.3.083 (no MFA), SC.3.177 (db.json unencrypted), SI.1.210 (22-day undetected dwell), SI.2.216 (no malware scan)
OPS-06	No WAF, DLP, FIM, EDR, MFA, secrets manager, git scanning, backup system, cyber insurance on any host; CEO $1 salary signals cash conservation; CFO under Sales reduces objective security budget review; C-suite payroll ($345K) = ~30% of estimated $1.15M total payroll
LEG-01	PCI SSC 2023: fines $5K-$100K/month/card brand x4 brands; IBM Cost of a Data Breach 2024: global avg $4.88M; Ponemon 2024: notification $180/record x est. 50K cards; 18MB db.json confirmed active exfiltration as of 2026-03-27
LEG-02	SS7: 34 contract/NDA/pricing emails exfiltrated to ProtonMail; Advisen/NetDiligence 2023: median SMB cyber lawsuit settlement $265K; Morrison & Foerster Cyber Incident Response Guide 2024: legal defense $100K-$400K
LEG-03	SS2: 14GB flight-control-core, telemetry-stack, groundstation-ui exfiltrated; DTSA 18 U.S.C. Section 1836: actual damages + unjust enrichment + exemplary 2x; Littler 2024: average trade secret verdict $3.2M; DJI v. Autel Robotics 2019: comparable drone IP settlement >$5M
LEG-04	SS3: 86 employee SSO credentials harvested; WEB/DS: 18MB payment card data confirmed exfiltrated (db.json); Ponemon 2024: avg class action settlement $3.1M for SMB breach under 100K records; FTC consent orders: Target $18.5M, Home Depot $17.5M scaled to SMB
LEG-05	Drone Masters acquisition in progress per cybersimsky.md; 22-day confirmed breach requires M&A due diligence disclosure; Kirkland & Ellis 2023 M&A Cyber Study: 23% of deals renegotiated post-breach; MAC clause invocation = 15-40% price haircut or termination plus breakup fee $500K-$2M; CrowdStrike/SolarWinds precedents for deal repricing

10 Appendix C: Key References

- **Verizon DBIR 2024**: verizon.com/business/resources/reports/dbir/
- **IBM Cost of a Data Breach 2024**: ibm.com/reports/data-breach
- **CISA Known Exploited Vulnerabilities**: cisa.gov/known-exploited-vulnerabilities-catalog
- **FIRST CVSS v3.1 Specification**: first.org/cvss/specification-document
- **FBI IC3 Annual Report 2023**: ic3.gov/Media/PDF/AnnualReport/2023_IC3Report.pdf
- **NetDiligence Cyber Claims Study 2023**: netdiligence.com/cyber-claims-study
- **Littler Trade Secrets Annual Report 2024**: littler.com/publication-press/publication/trade-secrets-annual-report
- **DTSA 18 U.S.C. §1836**: uscode.house.gov – 18 U.S.C. §1836
- **FAIR Institute Standard v3.0 (Jan 2025)**: fairinstitute.org/fair-standard
- **Agresti & Coull 1998 (Wilson CI)**: *The American Statistician* 52(2):119–126
- **Kirkland & Ellis M&A Cyber Study 2023**: kirkland.com/publications
- **Morrison & Foerster Cyber IR Guide 2024**: mofo.com/resources/insights
- **PCI SSC – PCI-DSS v4.0**: pcisecuritystandards.org
- **MITRE ATT&CK Enterprise v15**: attack.mitre.org
- **CrowdStrike Global Threat Report 2024**: crowdstrike.com/global-threat-report/

11 Appendix D: Session Info

```r
sessionInfo()
```

```
## R version 4.4.1 (2024-06-14 ucrt)
## Platform: x86_64-w64-mingw32/x64
## Running under: Windows 11 x64 (build 22631)
##
## Matrix products: default
##
##
## locale:
## [1] LC_COLLATE=English_United States.utf8
## [2] LC_CTYPE=English_United States.utf8
## [3] LC_MONETARY=English_United States.utf8
## [4] LC_NUMERIC=C
```

```
## [5] LC_TIME=English_United States.utf8
##
## time zone: America/New_York
## tzcode source: internal
##
## attached base packages:
## [1] stats     graphics  grDevices utils     datasets  methods   base
##
## other attached packages:
##  [1] ggrepel_0.9.6    ggridges_0.5.6   patchwork_1.3.0  scales_1.3.0
##  [5] kableExtra_1.4.0 knitr_1.48       mc2d_0.2.1       mvtnorm_1.3-6
##  [9] lubridate_1.9.3  forcats_1.0.0    stringr_1.5.1    dplyr_1.1.4
## [13] purrr_1.0.2      readr_2.1.5      tidyr_1.3.1      tibble_3.2.1
## [17] ggplot2_3.5.1    tidyverse_2.0.0
##
## loaded via a namespace (and not attached):
##  [1] gtable_0.3.5       xfun_0.47          rstatix_0.7.2      tzdb_0.5.0
##  [5] vctrs_0.6.5        tools_4.4.1        generics_0.1.4     parallel_4.4.1
##  [9] fansi_1.0.6        highr_0.12         pkgconfig_2.0.3    RColorBrewer_1.1-3
## [13] lifecycle_1.0.5    compiler_4.4.1     farver_2.1.2       textshaping_0.4.0
## [17] munsell_0.5.1      carData_3.0-6      htmltools_0.5.8.1  yaml_2.3.10
## [21] Formula_1.2-5      crayon_1.5.3       pillar_1.9.0       car_3.1-3
## [25] ggpubr_0.6.0       abind_1.4-8        tidyselect_1.2.1   digest_0.6.37
## [29] stringi_1.8.7      labeling_0.4.3     fastmap_1.2.0      grid_4.4.1
## [33] colorspace_2.1-2   cli_3.6.3          magrittr_2.0.4     utf8_1.2.6
## [37] broom_1.0.6        withr_3.0.2        backports_1.5.0    bit64_4.6.0-1
## [41] timechange_0.3.0   rmarkdown_2.28     bit_4.6.0          ggsignif_0.6.4
## [45] hms_1.1.3          evaluate_1.0.5     viridisLite_0.4.3  rlang_1.1.4
## [49] Rcpp_1.1.1         glue_1.8.0         xml2_1.5.2         svglite_2.2.2
## [53] rstudioapi_0.18.0  vroom_1.6.5        R6_2.6.1           systemfonts_1.3.2
```